הנחיות אבטחת מידע לחברת שירותי מחשוב

ארגון לדוגמה | גרסה 1.0 | 13 באוקטובר 2026

המסמך מגדיר מדיניות מוצעת להגנת מערכות המחשוב והמידע בחברת שירותים בת 50 עובדים. הוא מיועד למנהל המחשוב, לאחראי אבטחת המידע ולבעלי המערכות, ומפרט מה להגדיר, מי אחראי וכיצד לבדוק את הביצוע. ההנחות, זמני הטיפול וספי הבקרה שלהלן נבחרו לצורך תרגול ארגוני.

תחולה ואחריות

התחולה כוללת עובדים, קבלנים, גישה מרחוק, מחשבי קצה, תשתיות מקומיות ושירותי ענן. מנהל המחשוב מפעיל את הבקרות; אחראי אבטחת המידע בודק חריגות וסיכונים; בעל המידע מאשר הרשאות ושמירה; ההנהלה מאשרת חריגים ותקציב. לכל חריג ייקבעו בעלים, בקרה מפצה ותאריך סיום. סקירת המדיניות תתבצע אחת לשנה ולאחר אירוע משמעותי. [1]

מיפוי המערכות והמידע

נכס או מערכת	מידע או תפקיד	בקרה מרכזית
מחשבים ניידים ונייחים	מסמכי עבודה וגישה לשירותים	הצפנת דיסק והגנת קצה
טלפונים ארגוניים	דואר וקבצי עבודה	ניהול מכשירים ונעילה
שירות זהויות מרכזי	חשבונות והרשאות	אימות נוסף והפרדת ניהול
דואר ואחסון בענן	תכתובות ושיתוף קבצים	בקרת שיתוף וניטור
שרת קבצים	מסמכי לקוחות וכספים	הרשאות לפי תפקיד וגיבוי
שרת אתר באזור נפרד	שירות לקוחות וממשק כניסה	תקשורת מוצפנת והקשחה
מסד נתונים	נתוני לקוחות ומשתמשים	גישה מצומצמת ולוגים
חומת אש וגישה מרחוק	ניתוב וסינון תעבורה	כללים מפורשים וביקורת
מתגים ורשת אלחוטית	חיבור עובדים ואורחים	הפרדת רשתות
מדפסות וציוד חכם	סריקות וניהול ציוד	רשת מוגבלת ועדכונים
מערכת גיבוי וניטור	שחזור וראיות לאירועים	ניהול נפרד והגנה ממחיקה

לכל נכס יירשמו בעלים, כתובת או מזהה, מערכת הפעלה, גרסה, מיקום, רגישות ותאריך בדיקה. מידע יסווג לציבורי, פנימי, חסוי או מוגבל; רשומות לקוחות, פרטי גישה ומידע כספי יוגבלו לבעלי תפקידים מורשים בלבד.

זהויות והרשאות

כל אדם ישתמש בחשבון אישי. פתיחת חשבון תחייב בקשה מאושרת ותפקיד מוגדר, והרשאות יינתנו לקבוצות תפקיד לפי הצורך. חשבונות ניהול יופרדו מחשבונות העבודה היומיומיים. אין להשתמש בחשבון מנהל לגלישה ולדואר. חשבונות שירות יקבלו רק הרשאות נחוצות וללא כניסה אינטראקטיבית כשאינה נדרשת.

אימות רב־שלבי יידרש למנהלים, לדואר, לגישה מרחוק ולמערכות עם מידע חסוי. יש להעדיף אמצעי אימות עמידים לדיוג כאשר המערכת תומכת בכך. סיסמאות יהיו באורך 15 תווים לפחות, ייבדקו מול רשימת סיסמאות נפוצות או דלופות ויישמרו במנהל סיסמאות. אין לחייב החלפה מחזורית ללא סיבה; יש להחליף בעקבות חשיפה, איפוס או חשד לפגיעה. [3]

בשינוי תפקיד יוסרו ההרשאות הקודמות. בסיום העסקה החשבון והחיבורים הפעילים יבוטלו במועד שנקבע עם משאבי אנוש, ויוחזר ציוד ארגוני. סקירת הרשאות תתבצע אחת לרבעון, ובחשבונות ניהול אחת לחודש. יש לבדוק גם מפתחות גישה, הרשאות ענן וחשבונות של ספקים.

מחשבי קצה ושרתים

מנהל המחשוב יפעיל הגנת קצה מנוהלת, חומת אש מקומית, הצפנת דיסק ונעילת מסך לאחר 10 דקות. יש להשתמש במערכות הפעלה נתמכות ולהסיר תוכנות ושירותים מיותרים. למשתמש רגיל לא יהיו הרשאות מנהל מקומיות קבועות. שימוש בהתקנים נשלפים יוגבל לפי צורך עסקי ויתועד.

יש להקשיח שרתים לפי תפקידם, להסיר חשבונות ברירת מחדל, לצמצם שירותים מאזינים ולהריץ שירותי יישום כמשתמש ייעודי שאינו מנהל. ניהול יתבצע מעמדת ניהול מוגנת. תצורת בסיס ורשימת שינויים יישמרו באופן שמאפשר חזרה למצב תקין.

עדכונים וניהול חולשות

מלאי הגרסאות ייבדק מדי חודש. במדיניות המוצעת, חולשה שמנוצלת בפועל בשירות חשוף תטופל בתוך 48 שעות באמצעות עדכון או בקרה מפצה; חולשה חמורה אחרת בתוך 7 ימים; יתר עדכוני האבטחה בתוך 30 ימים. לפני שינוי ייבדקו התאימות, הגיבוי ודרך החזרה לאחור. אלה יעדי טיפול של הארגון לדוגמה, ולא לוחות זמנים שנקבעו במקור חיצוני.

מידע ושירותי ענן

קבצים חסויים יישמרו במאגרים מאושרים עם הרשאות ותיעוד גישה. קישור ציבורי לשיתוף מידע חסוי ייחסם; שיתוף חיצוני יוגבל לנמען ולמועד. תוגדר תקופת שמירה לכל סוג מידע והמחיקה תתועד. סודות ומפתחות יישמרו במאגר סודות ייעודי, ללא הכללה בקוד, בדואר או בצילומי מסך. טלפונים ארגוניים ינוהלו במערכת ניהול מכשירים, כולל הצפנה ומחיקה מרחוק של מידע ארגוני.

הפרדת רשתות וחומת אש

הרשת תחולק לאזורי עובדים, שרתים, ניהול, אורחים, ציוד חכם וגיבויים. שירות המיועד ללקוחות ימוקם באזור שרתים נפרד. התעבורה בין האזורים תעבור דרך נקודת סינון; אין ליצור חיבור חלופי שמאפשר לעקוף אותה. רשת אורחים תאפשר יציאה לאינטרנט בלבד. [2]

מדיניות ברירת המחדל בין אזורים היא חסימה. כל כלל היתר יכלול מקור, יעד, פרוטוקול, פורט, צורך עסקי ובעלים. כללים זמניים יקבלו תאריך פקיעה. ההרשאות ייבדקו אחת לרבעון, וכל שינוי ייבדק גם באמצעות ניסיון חיבור מותר וגם באמצעות ניסיון חיבור שאמור להיחסם.

דוגמת מדיניות תעבורה

מקור	יעד	שירות מותר	תנאי
לקוחות מורשים	שרת האתר	TCP 443	גישה ליישום בלבד
עמדת ניהול	שרתים וציוד רשת	פורטי הניהול הנדרשים	יעדים מפורשים ואימות חזק
שרת האתר	שרת מסד הנתונים	פורט מסד הנתונים בלבד	רק אם קיים שרת מסד נפרד
תחנות ושרתים	שרתי תשתית מאושרים	שמות מתחם וזמן	שרתים מוגדרים בלבד
מערכת הגיבוי	מקורות הגיבוי	פורטי מוצר הגיבוי	חשבון מוגבל ולפי כיוון החיבור
כל מקור אחר	אזור אחר	אין	חסימה ותיעוד לפי צורך

תעבורת זהויות, דואר, עדכונים ותלויות יישום תתווסף לפי מיפוי המערכות בפועל. הטבלה אינה רשימת הפורטים המלאה של סביבת דומיין. אם מסד הנתונים הוא קובץ מקומי, כגון SQLite, אין צורך לפתוח עבורו פורט רשת.

גישה מרחוק וניהול

גישה מרחוק תעבור דרך שירות מאושר עם אימות רב־שלבי וחשבונות אישיים. גישת ספק תינתן לזמן מוגבל וליעדים מוגדרים. ממשקי הניהול של חומת האש, הווירטואליזציה והגיבוי יהיו זמינים מרשת הניהול בלבד. אין לפרסם ממשקי ניהול ישירות לאינטרנט.

יישום במעבדה הווירטואלית

לתרגול ניתן להציב מכונת OPNsense עם שני ממשקי רשת, בין רשת הבדיקה לרשת השרת. השרת יתחבר לרשת המוגנת בלבד בזמן בדיקות הסינון. יש לוודא שהלקוח והשרת נמצאים בשתי רשתות שונות, שהניתוב עובר בחומת האש ושמופיעות רשומות תעבורה מתאימות בלוג. התקנת חומת אש ללא מעבר תעבורה דרכה אינה מוכיחה הגנה. [7]

לפני שינוי כתובות או ממשקים יישמר גיבוי תצורה ותיבדק גישה למסוף המכונה. לאחר שינוי יש לבדוק קישוריות, שמות מתחם, גישה ליישום וחסימה לשירותים שלא אושרו. ההפעלה במעבדה תתועד בנפרד ממדיניות זו.

אבטחת יישום האתר ומסד הנתונים

היישום יבדוק קלט בצד השרת לפי סוג, אורך ותחום ערכים. שאילתות למסד הנתונים יעבירו ערכים כפרמטרים ולא יחברו קלט משתמש למחרוזת SQL. תצוגת קלט משתמש תעבור קידוד מתאים להקשר. בדיקת הרשאות תתבצע בכל פעולה רגישה בצד השרת, גם כאשר קישור או כפתור מוסתרים בממשק.

סיסמאות יישמרו באמצעות פונקציה ייעודית לגיבוב סיסמאות עם מלח אקראי ועלות חישוב מתאימה. יש לבחור אלגוריתם ופרמטרים לפי ההנחיות העדכניות ולמדוד עומס על השרת. אין לשמור סיסמה גלויה או להשתמש בגיבוב מהיר רגיל כתחליף. גישה למסד הנתונים ולגיבוויו תוגבל לזהות השירות ולמנהלים מורשים. [4]

התחברות וניהול חיבור משתמש

המערכת תפיק מזהה חיבור אקראי לאחר התחברות מוצלחת, תחליף אותו בעת התחברות מחדש ותשמור בצד השרת שיוך למשתמש ומועד פקיעה. התנתקות תבטל את החיבור בשרת. במדיניות המוצעת, חיבור יפוג אחרי 30 דקות ללא פעילות ובכל מקרה לאחר 8 שעות. שינוי סיסמה או אירוע חשיפה יבטלו חיבורים קיימים לפי הסיכון. [5]

עוגיית החיבור תוגדר עם Secure ו־HttpOnly ועם מדיניות SameSite מתאימה. בקשות משנות מצב יוגנו מפני זיוף בקשות; אין לבצע שינוי באמצעות בקשת GET. פעולות כגון שינוי סיסמה או הרשאות יחייבו אימות חוזר. אין לכלול מזהה חיבור בכתובת הדף, בצילום מסך או בלוג. [5]

ניסיונות כניסה יוגבלו לפי חשבון ולפי מקור, תוך התחשבות במשתמשים החולקים כתובת רשת. ספי המעבדה ייבחנו מול שימוש צפוי לפני הרחבת החשיפה. הודעת כישלון התחברות תהיה כללית. יוגדרו התרעות על רצף כישלונות ועל כניסה חריגה, בלי לרשום את הסיסמה. [3]

הצפנת התקשורת והפעלה

גישה ליישום תתבצע באמצעות HTTPS עם תעודה תקפה ומהימנה ללקוח, תמיכה ב־TLS 1.3 ובמידת הצורך TLS 1.2. גרסאות ישנות יושבתו. מפתחות פרטיים יוגבלו לזהות השירות, ולחידוש התעודה תהיה התרעה. במעבדה יש להפיץ את אמון תעודת המעבדה ללקוח במקום להסתמך על התעלמות קבועה מאזהרות. [6]

בפריסה קבועה יופעל שרת יישום מתאים מאחורי שרת חזית, עם מצב ניפוי שגיאות כבוי ועם כתובות מארח ומקורות מאושרים. יש להגדיר מגבלות בקשה, כותרות אבטחה ורישום אירועים. אם קיימים כמה תהליכי שרת, מוני הגבלת הבקשות יהיו משותפים ביניהם. כל רכיב חדש ייכלל במלאי ובתהליך העדכונים.

לוגים ובקרה

יש לאסוף התחברויות, התנתקויות, שינויי הרשאות, חסימות רשת, אירועי הגנת קצה ושגיאות יישום. הרשומות יכללו זמן מסונכרן, מקור, פעולה ותוצאה. במדיניות המוצעת יישמרו 90 ימים נגישים ועוד עד שנה בארכיון מוגן, בכפוף לסיווג המידע. אחראי האבטחה יבדוק התרעות ויוודא שהלוגים אינם כוללים סיסמאות, מפתחות או מזהי חיבור פעילים.

גיבויים התאוששות וטיפול באירוע

מידע עסקי חיוני יגובה מדי יום, ותישמר גם גרסה המוגנת משינוי או מנותקת מגישת חשבונות העבודה. חשבון הגיבוי יופרד מחשבונות הניהול היומיומיים. אחת לחודש תבוצע בדיקת שחזור מדגמית, ואחת לרבעון שחזור שירות מלא בסביבה נפרדת. יש לתעד משך שחזור, שלמות מידע ובעיות שהתגלו. [2]

לתרגול זה הוגדרו יעד אובדן נתונים מרבי של 24 שעות ויעד חזרת שירות של 8 שעות. בעל המערכת יוודא שהגיבוי והתרגיל עומדים ביעדים אלה, ויחמיר אותם אם הצורך העסקי מחייב. הצלחת משימת הגיבוי כשלעצמה אינה מעידה שהשחזור עובד.

עובד יפנה מיד לתמיכה כשמופיעים חשד לדיוג, אובדן ציוד, תוכנה חשודה או גישה בלתי צפויה. התמיכה תפתח אירוע ותעבירו לאחראי האבטחה. הטיפול יכלול סיווג, בידוד לפי הצורך, שימור ראיות, בירור היקף הפגיעה, תיקון ושחזור מאומת. יישמרו ציר זמן ופעולות שבוצעו. ההנהלה ובעלי התפקידים יקבלו עדכונים בהתאם להשפעה. [2]

בדיקות קבלה ותחזוקה

בדיקה	ראיה נדרשת	תדירות מוצעת
הרשאות וחשבונות	רשימת זכאים ואישור בעלי המידע	רבעונית
חומת אש	חיבור מותר וחיבור חסום עם לוג תואם	לאחר שינוי ורבעונית
אתר והתחברות	בדיקות הרשאות חיבור הצפנה והגבלת בקשות	לפני פריסה ולאחר שינוי
גיבוי ושחזור	קובץ או שירות ששוחזרו ואומתו	חודשית ורבעונית
חולשות ועדכונים	דוח טיפול ובדיקה חוזרת של ממצאים	חודשית ולאחר ממצא חמור

בדיקות חדירה יוגדרו מראש לפי מערכות, שעות וכללי עבודה. ממצא יכלול ראיה ניתנת לשחזור, השפעה, חומרה מנומקת והמלצת תיקון. תוצאה שלא נבדקה תסומן כבדיקה ממתינה. סגירת ממצא תחייב בדיקה חוזרת ותיעוד, והדרכת עובדים תתקיים בקליטה ובהמשך אחת לחצי שנה.

מקורות מקצועיים

המקורות מספקים בסיס מקצועי לבקרות. היקף הארגון, התפקידים, ספי הזמן והיעדים במסמך הם בחירות מדיניות לצורך הדוגמה. תאריך עיון: 13 באוקטובר 2026.

[1] NIST SP 1300 — CSF 2.0 Small Business Quick Start Guide

[2] CISA — StopRansomware Guide

[3] OWASP — Authentication Cheat Sheet

[4] OWASP — Password Storage Cheat Sheet

[5] OWASP — Session Management Cheat Sheet

[6] OWASP — Transport Layer Security Cheat Sheet

[7] OPNsense — Virtual and Cloud Based Installation